IMSJ

ANÁLISIS DE

Ciberseguridad

Plataforma Web Educación Vial IMSJ

PHP NATIVO | ANÁLISIS Y DISEÑO SEGURO

Versión actualizada	**20/10/2026**
Asignatura	Electiva Ciberseguridad
Estado	Versión final

Este documento describe la implementación vigente en PHP nativo, conserva el mapa de riesgos del proyecto e incorpora debajo el criterio utilizado para su escala.

1. Alcance del análisis

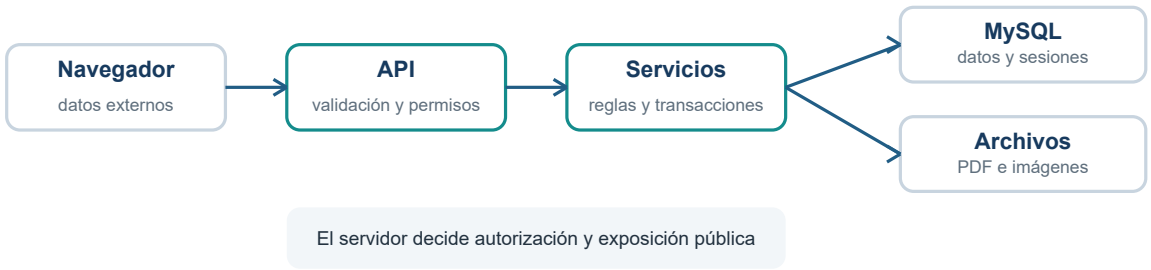
El análisis describe los activos, amenazas y controles de la versión PHP nativa y los relaciona con la evidencia disponible. Comprende el portal público, el panel IMSJ, la API, la base de datos, los archivos cargados y la infraestructura local Docker. La agenda y las reservas se evalúan como parte del alcance académico, aunque no formen parte de la entrega actual al cliente.

El análisis diferencia controles implementados, resultados registrados y límites de alcance. Las comprobaciones SAST, DAST, Nmap y Bash se documentan en sus informes específicos. La presencia de un control en el código no acredita por sí sola ausencia de vulnerabilidades; por eso cada resultado conserva su contexto y evidencia.

2. Activos y límites de confianza

Activo	Información o función que debe protegerse	Consecuencia de un incidente
Cuentas y contraseñas	Identidad, rol y acceso al panel y a reservas propias.	Suplantación y ejecución de operaciones no autorizadas.
Tokens de sesión	Acceso temporal a las operaciones de la cuenta.	Uso de una sesión robada hasta su vencimiento o revocación.
Noticias, materiales y FAQ	Integridad, aprobación, publicación y vigencia de la información.	Difusión de contenido falso, interno o desactualizado.
Consultas ciudadanas	Nombre, correo y mensaje.	Exposición de datos o uso de la bandeja para abuso y contenido malicioso.
Banco del simulador	Enunciados, gráficos, opciones y respuestas correctas.	Alteración educativa o exposición anticipada de la solución.
Reservas y franjas	Relación de ciudadano, horario y cupo.	Cancelación ajena, duplicación o exceso de capacidad.
Historial	Usuario, acción, elemento y fecha.	Pérdida de trazabilidad o atribución incorrecta de acciones.
Adjuntos y respaldos	PDF, imágenes, exportaciones y configuración de instalación.	Pérdida de información, descarga indebida o ejecución de archivos inseguros.

El navegador y sus datos se consideran entradas externas. Ocultar un botón no autoriza ni prohíbe una operación: la API debe comprobar la sesión y los permisos. La base y el almacenamiento se acceden desde el servidor; los archivos del backend fuera de `public` no deben publicarse como recursos estáticos.



3. Amenazas y efectos sobre el proyecto

Amenaza	Escenario relevante	Impacto técnico y sobre usuarios
Inyección SQL	Entradas manipuladas en acceso, filtros y operaciones de administración.	Lectura o modificación de cuentas, contenidos y datos de ciudadanos si una consulta concatena entradas sin control.
XSS almacenado o reflejado	Texto, enlaces o mensajes incorporados al DOM sin codificación contextual.	Ejecución en el navegador, redirección, alteración visual o robo del token accesible a JavaScript.
Fuerza bruta y robo de credenciales	Intentos automatizados, claves previsibles o engaño al personal.	Acceso a una cuenta y acciones atribuidas a su identidad.
Fallas de autorización	Invocar directamente una ruta administrativa o un identificador de otra cuenta.	Publicación sin permiso, lectura de información interna o cancelación de reservas ajenas.
Archivos inseguros	Carga de un archivo ejecutable, contenido distinto del tipo declarado o ruta manipulada.	Ejecución, exposición de archivos privados o consumo indebido de recursos.
Pérdida de integridad	Falla parcial entre SQL, historial y adjuntos, o solicitudes simultáneas por el último cupo.	Registros inconsistentes, archivos huérfanos o más reservas que capacidad.
Exposición de configuración	Publicación de `.env`, SQL, mensajes internos, logs o respaldos.	Filtración de claves y datos y acceso a servicios de la instalación.
Falta de recuperación	Pérdida de volumen o copia sin adjuntos, configuración o versión compatible.	Interrupción del servicio e imposibilidad de reconstruir su estado.

Mapa de riesgos

El mapa original se conserva y se interpreta sobre la implementación actual: backend en **PHP nativo, sin framework**, organizado por capas y con acceso a MySQL mediante PDO. La ubicación de los riesgos es una estimación cualitativa del equipo para priorizar revisiones; no sustituye una auditoría técnica ni una aceptación institucional del riesgo.

Código	Riesgo	Componente principal	Probabilidad	Impacto	Nivel	Justificación resumida
R1	Inyección SQL	Login, filtros y operaciones administrativas	Baja	Alto	Medio	El uso sistemático de PDO con consultas preparadas reduce la probabilidad, pero una regresión permitiría comprometer cuentas y datos.
R2	XSS almacenado	Noticias, materiales, FAQ y consultas	Media	Medio	Medio	Existen salidas seguras, aunque los usos de `innerHTML` y las URL construidas por el frontend requieren revisión contextual completa.
R3	Robo de credenciales o fuerza bruta	Acceso de personal y Directora	Alta	Alto	Alto	Bcrypt y el límite de intentos reducen ataques directos, pero no eliminan phishing, reutilización de claves ni robo del token accesible al navegador.
R4	Falla de control de acceso	API administrativa, contenidos y reservas	Media	Alto	Alto	La API verifica sesión, cuenta activa, rol y propiedad; un error en una ruta nueva o modificada tendría consecuencias amplias.

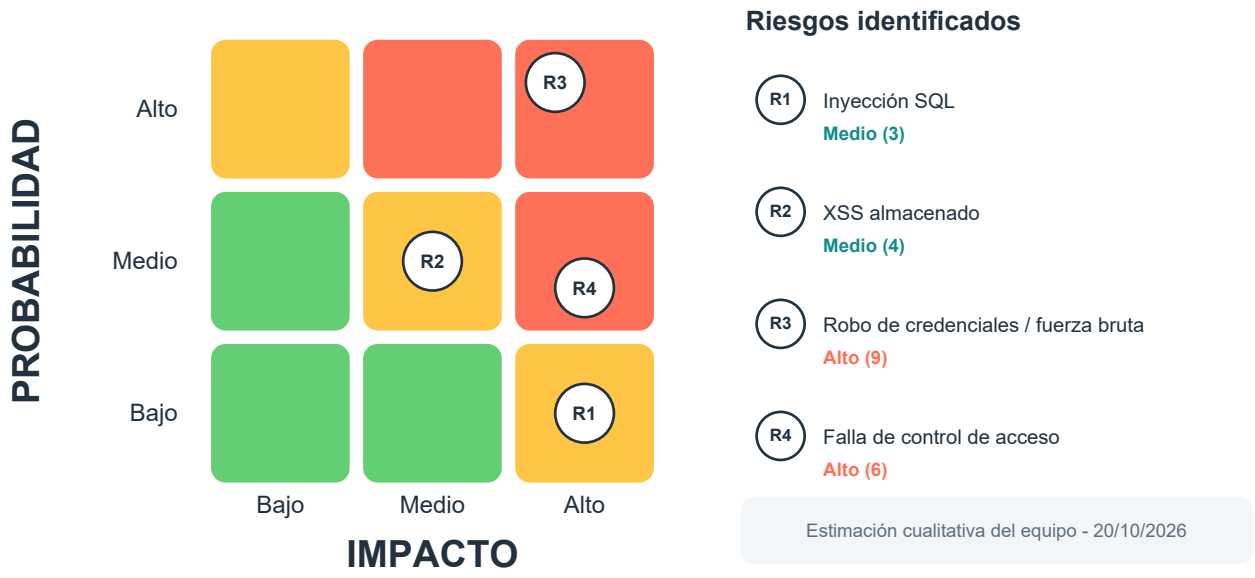


Figura 1. Mapa de riesgos del proyecto: probabilidad frente a impacto.

Criterio de escala del mapa. La probabilidad se valora como **Baja (1)** cuando el escenario exige condiciones excepcionales o los controles actuales reducen de forma clara su ocurrencia; **Media (2)** cuando el escenario es plausible y existe exposición o cobertura parcial; y **Alta (3)** cuando puede ocurrir con facilidad, depende también de factores humanos o los controles no bastan para prevenirlo. El impacto es **Bajo (1)** si el efecto es limitado, reversible y no compromete datos sensibles ni funciones críticas; **Medio (2)** si afecta temporalmente una función o un conjunto acotado de datos o usuarios; y **Alto (3)** si permite acceso privilegiado, exposición o alteración relevante de datos, publicación maliciosa o indisponibilidad significativa. El nivel se obtiene multiplicando probabilidad por impacto: **Bajo (1-2, verde)**, **Medio (3-4, amarillo)** y **Alto (6-9, rojo)**. La valoración fue realizada por el equipo del proyecto el 20/10/2026 y debe revisarse después de cada cambio relevante o nueva prueba de seguridad.

El mapa también conserva la relación con los componentes y efectos analizados originalmente:

Componente del sistema	Amenaza(s) asociada(s)	Impacto técnico	Impacto sobre usuarios
Login administrativo	Inyección SQL; robo de credenciales; fuerza bruta.	Omisión de autenticación, acceso a una cuenta y ejecución de acciones con permisos del personal.	Suplantación de identidad y atribución incorrecta de cambios en el historial.
Carga de contenidos	XSS almacenado; fallas de acceso; archivos inseguros.	Publicación o modificación no autorizada, almacenamiento de contenido malicioso y pérdida de integridad.	Información falsa, desactualizada o maliciosa desde un sitio identificado como oficial.
Consulta pública	XSS almacenado; exposición de contenido no publicado.	Ejecución en el navegador y visualización anticipada de contenido interno.	Redirecciones, contenido manipulado o acceso antes de su aprobación y vigencia.
Base de datos	Inyección SQL; acceso no autorizado.	Lectura, alteración o eliminación de cuentas, contenidos, consultas, reservas e historial.	Exposición de datos, pérdida de información pública o interrupción del servicio.

4. Controles presentes y límites

Área	Implementación disponible	Límite o evidencia adicional necesaria
Contraseñas	Hash bcrypt con costo 12 y `password_verify`; la salida del usuario omite el hash.	La política institucional de claves, recuperación y cuentas debe acordarse. El alta posterior de personal conserva una clave inicial fija.
Sesiones	Bearer opaco, secreto aleatorio de 32 bytes, hash SHA-256 y ocho horas de vigencia. Ingreso revoca sesiones previas; logout y desactivación revocan tokens.	`sessionStorage` es accesible a scripts del mismo origen; la prevención de XSS y HTTPS son necesarias en el entorno real.
Roles	Comprobación de cuenta activa y rol en cada operación protegida; Directora hereda acceso de personal y es la única que aprueba.	La asignación y revisión institucional de permisos no se deduce de las cuentas de demostración.
Intentos de acceso	Cinco intentos por minuto por IP y operación para login/registro, con contador y bloqueo de archivo compartido.	No es un limitador general de todas las rutas; varias instancias necesitan caché compartida.
SQL e integridad	PDO preparado, transacciones, claves foráneas y restricciones únicas. Reserva bloquea la franja antes de comprobar cupo.	La parametrización no sustituye los permisos y las reglas de negocio.
Entradas y errores	`Solicitud` valida JSON/multipart, tipos, tamaños, opciones, fechas, horas, cédulas y URL. Los errores internos no devuelven SQL o claves.	La validación del navegador es complementaria. Se debe revisar cada contexto de salida de HTML y URL.
Archivos	MIME/contenido, límites por recurso, nombres aleatorios y rutas restringidas fuera de `public`.	VIDEO usa URL externa; los proveedores y sus condiciones deben definirse para la operación institucional.
Publicación	Estados Borrador, Pendiente, Aprobado y Publicado; edición devuelve a borrador y noticias se filtran por vigencia.	Una aprobación técnica de contenido no es una aceptación del proyecto.
Auditoría	Operaciones administrativas guardan usuario, acción, fecha y elemento en la misma transacción de datos.	No conserva valores anterior/nuevo; cobertura total y retención están por acordar. La cancelación ciudadana elimina la reserva sin estado histórico.
Infraestructura	MySQL sin puerto del host, frontends montados en lectura y raíz Apache limitada a `public`.	La configuración local no incorpora dominio ni HTTPS de producción; falta evidencia final de hardening y recuperación.

5. Superficies específicas

Contenidos y consultas

Noticias, materiales y FAQ se administran con sesión y permisos. El portal solo debe consumir la representación pública. La bandeja de consultas contiene datos personales y su lectura requiere acceso de personal; el formulario público no expone su listado. La revisión de salida debe considerar los módulos que utilizan `innerHTML`, además de los que construyen nodos con `textContent`.

Simulacro

La consulta pública omite la respuesta correcta. La corrección obtiene la solución desde la base, sin aceptar del navegador una marca de respuesta verdadera. Las imágenes admitidas son JPG, PNG y WEBP de hasta 2048 KB. Debe comprobarse tanto la carga válida como el rechazo de contenido ejecutable y la descarga del recurso almacenado.

Agenda académica

La reserva se asocia a la cuenta del token. La transacción y el bloqueo impiden superar el cupo por solicitudes simultáneas, y la unicidad evita duplicación por ciudadano/franja. La ruta DELETE comprueba el propietario; personal recibe rechazo de rol y otra cuenta ciudadana no puede eliminar el registro. El borrado libera capacidad y no conserva un historial de cancelación.

Los listados solo muestran fechas vigentes; ese filtro de presentación no elimina los registros pasados ni define su conservación. La política de retención debe contemplar datos efectivamente guardados, no solo lo que la interfaz permite ver.

6. Evidencia final

La entrega reúne evidencia técnica de las tres etapas de Ciberseguridad:

- Análisis de amenazas, mapa de riesgos y controles aplicables.
- Semgrep con hallazgos y correcciones documentadas.
- OWASP ZAP y Nmap sobre el entorno local autorizado.
- Auditoría Bash de autenticación, permisos, entradas y archivos.
- Hardening de Apache/PHP y MySQL mediante Docker Compose.
- Registro de hallazgos y procedimiento de respuesta a incidentes.
- Términos y privacidad incluidos; los datos institucionales se completarán con información validada por la Intendencia.

7. Cierre

Las pruebas se realizaron sobre el entorno local autorizado y con datos de prueba. Los resultados describen el alcance evaluado y no afirman ausencia absoluta de vulnerabilidades. No se atacaron sistemas externos ni se utilizaron datos personales reales.

8. Referencias

- Requisitos, arquitectura, infraestructura y contrato de API.
- OWASP SQL Injection.
- OWASP XSS Prevention.
- OWASP Authentication y Authorization.
- OWASP Input Validation y Password Storage.
- OWASP Logging y File Upload.